4 Authorization: What can you do?

This chapter covers

- A look at why authentication isn’t enough—and why authorization deserves focused attention
- The PARC model for breaking down access decisions
- Core terminology that underpins modern authorization systems, from roles and attributes to policies and entitlements
- A tour of the authorization reference architecture and how its components work together
- Real-world deployment patterns for enforcing and evaluating policies in centralized and distributed systems

In 2023, the U.S. Federal Trade Commission (FTC) filed a complaint against Ring, the popular home security company owned by Amazon. The allegations were startling: employees and third-party contractors had unrestricted access to customers’ private video feeds—sometimes without their knowledge or consent. In a particularly egregious case, one employee viewed thousands of videos of female customers in their bedrooms and bathrooms over several months before being discovered.

What went wrong? From a traditional access control standpoint, the individuals involved were all authenticated. They had usernames and passwords. They were Ring employees or authorized contractors. The system knew who they were.

But that wasn’t the issue. The real failure lay in authorization—the system lacked controls to determine what these authenticated users were allowed to do. There were no meaningful limits on who could view customer video feeds, no contextual checks, and no policy-based enforcement. The system trusted too much.